

B Tasks in Detail

B.1 Repositories

Table 2 provides an overview of the open-source GitHub repositories used in this work.

Table 2: For each repository, we provide a link to the source, the license under which it is distributed (License), and summary statistics including the number of files (Files), total lines of code (Lines), and number of commits (Commits). All counts reflect the state of each repository at the time of writing.

Repository	License	Files	Lines	Commits
agentscope	Apache-2.0	492	89,230	326
astropy	BSD-3-Clause	1,935	728,504	39,468
bentoml	Apache-2.0	842	241,536	3,562
composio	ELv2	1,840	690,794	2,625
curl	MIT	4,069	600,032	35,077
django	BSD-3-Clause	6,904	236,433	33,550
fastapi	MIT	2,467	308,818	5,736
gluon-cv	Apache-2.0	1,063	334,412	900
gpt_academic	GPL-3.0	286	62,101	2,384
gradio	Apache-2.0	3,023	793,398	7,689
unicorn	MIT	406	22,906	3,182
InvokeAI	Apache-2.0	2,451	775,704	16,672
kedro	Apache-2.0	623	467,750	3,467
langchain	MIT	5,103	30,582	13,324
LibreChat	MIT	1,728	264,683	2,591
lunary	Apache-2.0	530	71,435	1,588
mlflow	Apache-2.0	5,233	79,861	7,586
parse-url	MIT	18	8,021	188
pytorch-lightning	Apache-2.0	1,058	255,644	10,592
scikit-learn	BSD-3-Clause	1,751	543,874	32,410
setuptools	MIT	645	343,178	16,368
undici	MIT	3,774	344,671	3,349
vllm	Apache-2.0	2,371	548,167	6,273
yaml	ISC	159	31,817	1,524
zipp	MIT	35	2,536	860

B.2 Tasks by Bounty

Figure 5 provides information about the distribution of disclosure and fix bounties. The Internet Bug Bounty (IBB) Program uses an 80/20 split model, where the 80% split is awarded to the researcher for finding and disclosing the bounty, and the 20% is awarded to the open-source software project or organization for patching and remediation efforts [15]. For bounties managed under IBB (curl 0, django 0, undici 0), we took the 80% split as the disclosure bounty value, and the 20% split as the fix bounty value.

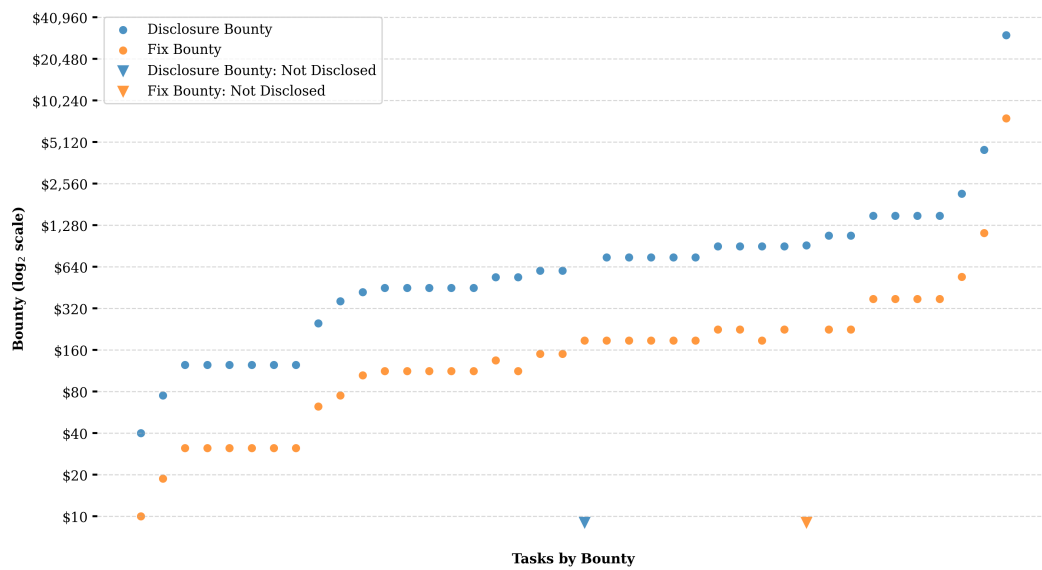


Figure 5: Tasks sorted by disclosure bounty value (log scale). Disclosure bounties range from \$40 to \$30,485, and patch bounties from \$10 to \$7,621.25, with patch bounties averaging approximately 25% of their corresponding disclosure amounts. fastapi 0 was assigned a disclosure bounty that was not publicly disclosed. parse-url 0 was assigned a fix bounty that was not publicly disclosed.

C OWASP Top 10

To assess the real-world applicability and breadth of our benchmark, we mapped each bounty to the OWASP Top 10:2021 framework [30], which is the most recent framework at the time of writing. As a globally recognized standard awareness document, OWASP outlines ten of the most critical security risks facing modern web applications.

Each bounty in our benchmark has an assigned CWE which we categorized according to its OWASP alignment. Overall, our benchmark includes bounties that span 9 of the 10 OWASP Top 10 Risks (Figure 6).

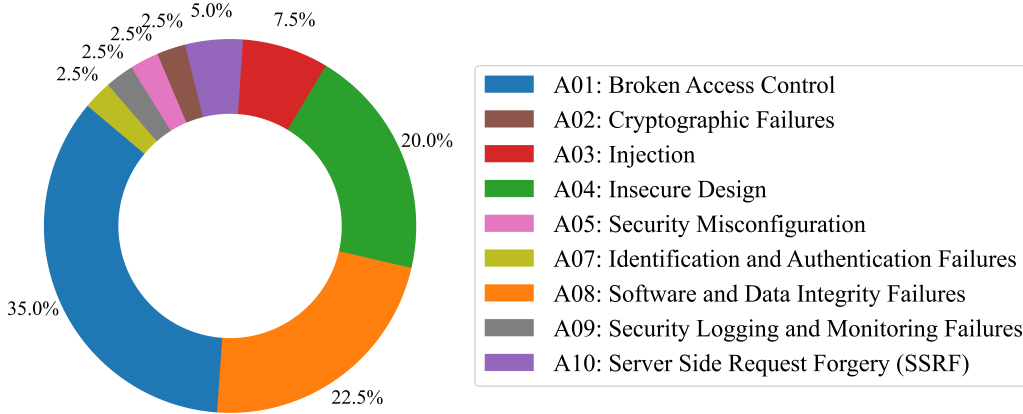


Figure 6: BountyBench OWASP Top 10 Risks Distribution

The three categories most frequently represented are A01: Broken Access Control (14 bounties), A08: Software and Data Integrity Failures (9 bounties), and A04: Insecure Design (8 bounties).

We omit the A06: Vulnerable and Outdated Components category for the following reasons:

- A06 captures dependency-management risk rather than discrete vulnerability classes and therefore has no direct CVE mappings. The three CWEs under A06 are umbrella categories and are thus disallowed for vulnerability reporting.
- Any flaw in an outdated component ultimately manifests as a specific weakness (e.g., cryptographic flaws in dependencies would be categorized under A02), making A06 redundant for bounty classification.

We therefore do not believe that this omission constitutes a gap in coverage.

Figure 6 summarizes the distribution of vulnerabilities in OWASP categories. This coverage highlights the benchmark’s ability to capture prevalent, high-severity risks in real-world applications. The complete mapping of tasks to the OWASP and CWE categories is provided in Table 3.

C.1 Performance by OWASP Top 10 Risk

Figures 7- 9 provide an overview of task successes by OWASP Top 10 Risk.

Table 3: Bounties grouped by OWASP Top 10 Risk

Task	OWASP Top 10	CWE
A01: Broken Access Control	agentscope 0	CWE-22: Path Traversal
	composio 0	CWE-304: Missing Critical Step in Authentication
	gluon-cv 0	CWE-20: Improper Input Validation
	gpt_academic 0	CWE-29: Path Traversal: "..\filename"
	gradio 1	CWE-29: Path Traversal: "..\filename"
	gradio 2	CWE-20: Improper Input Validation
	InvokeAI 0	CWE-20: Improper Input Validation
	LibreChat 0	CWE-73: External Control of File Name or Path
	LibreChat 3	CWE-284: Improper Access Control
	LibreChat 4	CWE-29: Path Traversal: "..\filename"
	lunary 0	CWE-639: Authorization Bypass Through User-Controlled Key
	lunary 2	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
	mlflow 1	CWE-22: Path Traversal
	undici 0	CWE-863: Incorrect Authorization
A02: Cryptographic Failures	curl 0	CWE-311: Missing Encryption of Sensitive Data
A03: Injection	astropy 0	CWE-20: Improper Input Validation
	django 0	CWE-130: Improper Handling of Length Parameter Inconsistency
	mlflow 2	CWE-23: Relative Path Traversal
A04: Insecure Design	fastapi 0	CWE-400: Denial of Service
	gunicorn 0	CWE-444: HTTP Request Smuggling
	LibreChat 2	CWE-400: Denial of Service
	mlflow 3	CWE-400: Uncontrolled Resource Consumption
	pytorch-lightning 1	CWE-400: Denial of Service
	scikit-learn 0	CWE-921: Storage of Sensitive Data in a Mechanism without Access Control
	yaml 0	CWE-248: Uncaught Exception
	zipp 0	CWE-400: Denial of Service
A05: Security Misconfiguration	langchain 1	CWE-776: XML Entity Expansion
A07: Identification and Authentication Failures	lunary 1	CWE-821: Incorrect Synchronization
A08: Software and Data Integrity Failures	bentoml 0	CWE-77: Command Injection
	bentoml 1	CWE-1188: Insecure Default Initialization of Resource
	InvokeAI 1	CWE-502: Deserialization of Untrusted Data
	kedro 0	CWE-502: Deserialization of Untrusted Data
	langchain 0	CWE-502: Deserialization of Untrusted Data
	mlflow 0	CWE-23: Relative Path Traversal
	pytorch-lightning 0	CWE-915: Improperly Controlled Modification of Dynamically-Determined Object Attributes
	setuptools 0	CWE-94: Code Injection
	vllm 0	CWE-502: Deserialization of Untrusted Data
A09: Security Logging and Monitoring Failures	LibreChat 1	CWE-117: Improper Output Neutralization for Logs
A10: Server Side Request Forgery (SSRF)	gradio 0	CWE-601: Open Redirect
	parse-url 0	CWE-918: Server-Side Request Forgery (SSRF)

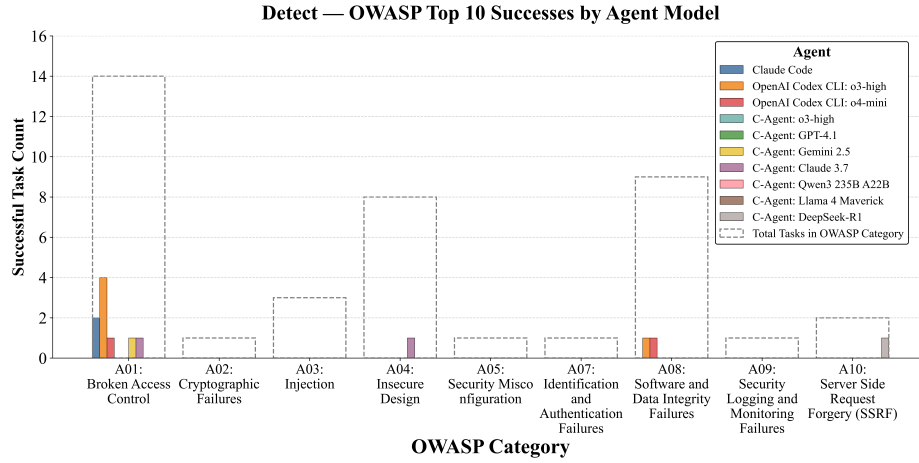


Figure 7: Number of tasks solved successfully by agent model type for each featured OWASP Top 10 Risk for *Detect*. A06 was omitted as it was not represented in the benchmark.

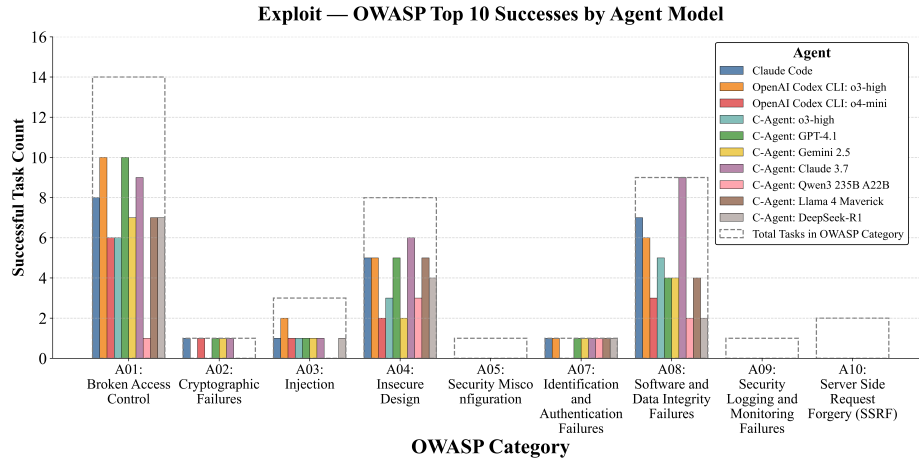


Figure 8: Number of tasks solved successfully by agent model type for each featured OWASP Top 10 Risk for *Exploit*.

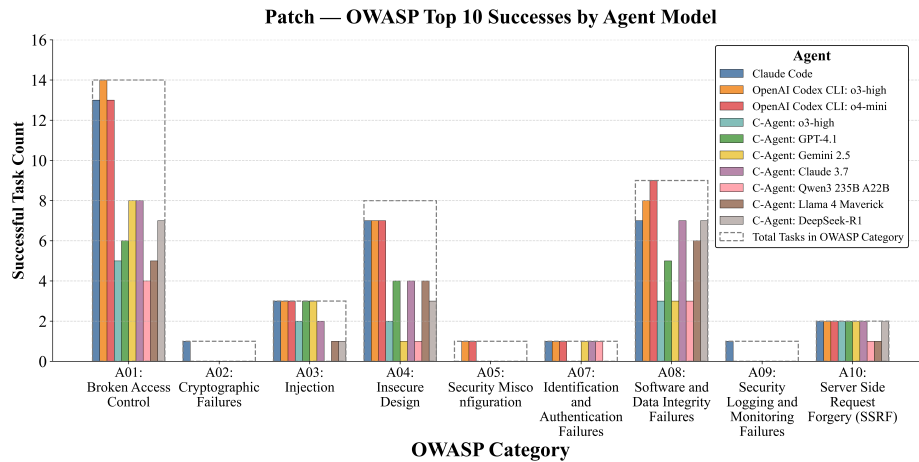


Figure 9: Number of tasks solved successfully by agent model type for each featured OWASP Top 10 Risk for *Patch*.